

Anexo de Privacidad y Protección de Datos

1. MARCO NORMATIVO Y CUMPLIMIENTO LEGAL

ISA-Home tiene un estricto cumplimiento de la normativa europea y nacional, dado su despliegue en el entorno doméstico (privacidad) y su naturaleza autónoma (seguridad).

1.1. RGPD (Reglamento General de Protección de Datos)

Al tratar datos personales (voz, imagen) y categorías especiales (datos de salud/alergias, Art. 9), el sistema se basa en:

- **Base Jurídica (Arts. 6 y 9):** El tratamiento se legitima exclusivamente mediante el **consentimiento explícito e informado** recabado durante la instalación (Check-in inicial).
- **Derechos ARCO y Olvido (Art. 17):** Se garantiza la revocación del consentimiento en cualquier momento mediante la App, ejecutando un borrado seguro de los modelos biométricos locales.
- **Responsabilidad Proactiva:** Designación obligatoria de un **Delegado de Protección de Datos (DPO)** conforme al Art. 37, debido a la observación sistemática a gran escala de personas en sus hogares.

1.2. LOPD-GDD

Se aplica la normativa española complementaria, con foco crítico en la protección de menores:

- **Consentimiento de Menores (Art. 7):** Dado que los menores de 14 años no pueden prestar consentimiento válido por sí mismos, ISA-Home **bloquea por defecto** el procesamiento de datos de menores hasta que existe una autorización verificable de los tutores legales.
- **Derechos Digitales:** Se garantiza el derecho a la desconexión y a la transparencia sobre cuándo el robot está registrando información.

1.3. AI Act (Reglamento Europeo de IA)

ISA-Home se clasifica como **Sistema de Alto Riesgo** (Anexo III) al ser un componente de seguridad y asistencia personal. Obligaciones implementadas:

- **Supervisión Humana (Human-in-the-loop):** El usuario siempre tiene capacidad de intervención ("kill-switch") para anular decisiones del robot.
- **Prohibiciones:** Se excluyen explícitamente prácticas de riesgo inaceptable, como el reconocimiento de emociones en tiempo real o la categorización biométrica no consentida.

- **Registro:** Inscripción obligatoria en la base de datos de la UE para sistemas de alto riesgo.

1.4. DSA (Digital Services Act)

En lo referente a las recomendaciones activas (sugerencias de recetas o compras):

- **Transparencia Algorítmica:** El usuario tiene acceso a la lógica de decisión (¿Por qué me sugieres esto?) para evitar la manipulación del comportamiento.

2. PRIVACIDAD DESDE EL DISEÑO Y POR DEFECTO

La arquitectura de ISA-Home sigue el principio de **minimización de datos**. No se recolecta nada que no sea estrictamente funcional.

2.1. Arquitectura de Procesamiento Local (Edge AI)

Para mitigar riesgos de fugas masivas, ISA-Home prioriza el cómputo en el borde:

- **Voz y Vídeo:** Se procesan en la GPU local del robot. No se envían streams de audio/video a la nube.
- **Persistencia:** Los datos crudos son efímeros (se borran tras procesar la orden). Solo se guardan vectores de características (embeddings) cifrados.

2.2. Mapa de Datos y Ciclo de Vida

Categoría de Datos	Finalidad del Tratamiento	Ubicación del Proceso	Retención y Ciclo de Vida	Medidas de Seguridad
Voz y Comandos	Reconocimiento de órdenes (ASR/NLP)	Local (Robot/ISA-Point)	Efímera: Se elimina milisegundos después de ejecutar la acción.	Cifrado en tránsito (TLS 1.3). Indicador LED de micrófono activo.
Imagen y Video	Navegación (SLAM), detección de obstáculos y personas.	Local (Robot)	No se almacena: Solo se procesa el stream en tiempo real.	Procesamiento en memoria volátil (RAM). Indicador LED "Hard-wired".
Salud y Preferencias	Gestión de alérgenos,	Local + App (Sincronización opcional)	Persistente: Hasta la revocación del consentimiento	Cifrado en reposo. Acceso restringido

	dietas y rutinas de sueño.		o o solicitud de borrado.	biométricamente en App.
--	----------------------------	--	---------------------------	-------------------------

3. EVALUACIÓN DE IMPACTO (EIPD) Y GESTIÓN DE RIESGOS

Conforme al Art. 35 del RGPD, se ha realizado una Evaluación de Impacto identificando riesgos y salvaguardas:

Riesgo 1: Grabación No Consentida (Intrusión en la intimidad)

- **Descripción:** Captura accidental de conversaciones privadas o imágenes en momentos íntimos.
- **Nivel:** Alto.
- **Mitigación Estrella:** Implementación de **indicadores "Hard-wired"**. Los LEDs de grabación cierran el circuito eléctrico de la cámara/micro. Es físicamente imposible que el software grabe sin que la luz se encienda, previniendo malware espía.

Riesgo 2: Tratamiento Ilícito de Datos de Menores

- **Descripción:** Procesamiento de voz o rutinas de niños sin autorización parental.
- **Nivel:** Muy Alto.
- **Mitigación:**
 1. **Reconocimiento de Edad:** El modelo estima si el usuario es menor.
 2. **Control Parental Estricto:** Si se detecta un menor y no hay "token" de autorización activo, el robot entra en modo pasivo (no procesa comandos ni guarda datos) (se bloquea).

Riesgo 3: Fuga de Datos (Data Breach)

- **Descripción:** Exfiltración de vídeos o mapas del hogar desde servidores externos.
- **Nivel:** Medio (gracias a la arquitectura local).
- **Mitigación:** Política de **"Nube Cero"** para datos biométricos. Los datos sensibles nunca salen de la red local (LAN) del hogar salvo backup cifrado explícitamente solicitado por el usuario.

Riesgo 4: Sesgos Algorítmicos

- **Descripción:** Discriminación en la calidad del servicio por acento, tono de piel o género.

- **Nivel:** Alto.
- **Mitigación:** Auditoría continua de los datasets de entrenamiento para garantizar diversidad y corrección técnica de sesgos en el modelo de reconocimiento.

REFERENCIAS A DOCUMENTOS DEL PROYECTO

[Sprint 1/Privacidad v1.pdf](#)

[Sprint 2/Riesgos y Límites/Emergencias v1.pdf](#)

[Sprint 2/Riesgos y Límites/ISA-Home riesgos lineas rojas v1.pdf](#)

[Sprint 2/Riesgos y Límites/RendiciónDeCuentas v1.pdf](#)

REFERENCIAS LEGALES Y TÉCNICAS

Reglamento (UE) 2016/679 (RGPD)

- *Art. 25 (Privacidad desde el Diseño):* Base de la arquitectura local.
- *Art. 35 (EIPD):* Fundamento de la matriz de riesgos presentada.
- [Enlace al BOE - RGPD](#)

Ley Orgánica 3/2018 (LOPD-GDD)

- *Art. 7 (Menores):* Base para la política de consentimiento parental (<14 años).
- *Tit. X (Derechos Digitales):* Garantía de desconexión y seguridad.
- [Enlace al BOE - LOPD-GDD](#)

Reglamento (UE) 2024/1689 (AI Act)

- *Anexo III:* Clasificación de robots autónomos como Alto Riesgo.
- *Art. 14 (Supervisión Humana):* Requisito de intervención manual y botón de parada.
- [Enlace EUR-Lex - AI Act](#)